ACCESS CONTROLS

WyIT 3005

PURPOSE: This policy implements technical policies and procedures for electronic information systems that maintain sensitive information to allow access only to those persons or software programs that have been granted access rights as specified by regulation or business process.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by WyIT - 3002 - Security Exception Request policy.

IV. GENERAL

All individuals identified in the scope of this policy are responsible for:

- Ensuring no other individual uses their unique ID
- Never using another individual's unique ID
- Abiding by the terms of this policy

V. SEPARATION OF DUTIES

All identified in the scope of this policy shall:

- Separate duties of individuals as necessary, to prevent malevolent activity without collusion
- Define information system access authorizations to support separation of duties

VI. LEAST PRIVILEGE

All identified in the scope of this policy shall:

- Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) which are necessary to accomplish assigned tasks in accordance with organizational missions and business functions.
- Authorize explicit access to hardware and software controlling access to systems and filtering rules for routers/firewalls, cryptographic key management information, configuration parameters for security services, and access control lists.
- Require that users of information system accounts, or roles, with access to State assets use non-privileged accounts or roles, when accessing non-security functions.
- Restrict privileged accounts on the information system.
- Ensure that the information system audits the execution of privileged functions.
- Ensure that the information system prevents non-privileged users from executing privileged functions to include disabling, circumventing, or altering implemented security safeguards and countermeasures.

VII. UNSUCCESSFUL LOGIN ATTEMPTS

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Enforce a limit of five (5) consecutive invalid logon attempts by a user.
- Lock the account/node automatically for 60 minutes or until released by an administrator when the maximum number of unsuccessful attempts is exceeded.

VIII. SYSTEM USE NOTIFICATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Display to users an approved system use notification message or banner before granting access to the system that provides privacy and security notices consistent with applicable state and federal laws, directives, policies, regulations, standards, and guidance and the State will inform that:
  - Users are accessing a State information system.
  - Information system usage may be monitored, recorded, and subject to audit.
  - Unauthorized use of the information system is prohibited and subject to criminal and civil penalties.
  - Use of the information system indicates consent to monitoring and recording.
  - There are no rights to privacy.
- Retain the notification message or banner on the screen until users acknowledge the usage conditions and take explicit actions to log on to or further access the information system.
- For publicly accessible systems, applicable agencies and/or affiliates shall ensure that the information system:
  - Displays system use information, before granting further access.
  - Displays references, if any, to monitoring, recording, or auditing that are consistent with privacy accommodations for such systems that generally prohibit those activities.
  - Includes a description of the authorized uses of the system.

IX. SESSION LOCK

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Prevent further access to the system by initiating a session lock after 15-minutes of inactivity or upon receiving a request from a user.
- Retain the session lock until the user reestablishes access using established identification and authentication procedures.
- Conceal, via the session lock, information previously visible on the display with a publicly viewable image.

X. SESSION TERMINATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that the information system automatically terminates a user session after 30-minutes of inactivity.

XI. PERMITTED ACTIONS WITHOUT IDENTIFICATION OR AUTHENTICATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Identify user actions that can be performed on the information system without identification or authentication, consistent with organizational missions and business functions.
- Document, via the security exception form, and provide supporting rationale for the information system, user actions not requiring identification or authentication.

XII. REMOTE ACCESS

In addition to meeting the requirements of WyIT-3017 Remote Access policy, all applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access.
- Authorize remote access to the information system prior to allowing such connections.
- Ensure that the information system monitors and controls remote access methods.
- Ensure that the information system implements cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions.
- Ensure that the information system routes all remote accesses through managed network access control points to reduce the risk for external attacks.
- Authorize the execution of privileged commands and access to security-relevant information via remote access only.
- Document the rationale for such access in the security plan for the information system.
- Users utilizing remote access services for connection into the State domain will utilize the State approved VPN solution. Users attempting to connect to the State domain using an unapproved access solution will be denied access.

XIII. WIRELESS ACCESS

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish usage restrictions, configuration/connection requirements, and implementation guidance for wireless access.
- Authorize wireless access to the information system prior to allowing such connections.
- Ensure that the information system protects wireless access to the system using authentication of users and devices and encryption.

XIV. ACCESS CONTROL FOR MOBILE DEVICES

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish usage restrictions, configuration requirements, connection requirements, and implementation guidance for organization-controlled mobile devices.
- Authorize the connection of mobile devices to organizational information systems.
- Employ full-device encryption or container encryption to protect the confidentiality and integrity of information on approved devices.

XV. USE OF EXTERNAL INFORMATION SYSTEMS

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish terms and conditions, consistent with any trust relationships established with other organizations owning, operating, and/or maintaining external information systems, allowing authorized individuals to:
  - Access the information system from external information systems.
  - Process, store, or transmit organization-controlled information using external information systems.
- Permit authorized individuals to use an external information system to access the information system or to process, store, or transmit organization-controlled information only when the organization:

- Verifies the implementation of required security controls on the external system as specified in the organization's information security policy and security plan.
- Retains approved information system connection or processing agreements with the organizational affiliate hosting the external information system.

XVI. INFORMATION SHARING

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Facilitate information sharing by enabling authorized users to determine whether access authorizations assigned to the sharing partner match the access restrictions of the information.

XVII. PUBLICLY ACCESSIBLE CONTENT

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Designate individuals authorized to post information onto a publicly accessible information system.
- Train authorized individuals to ensure that publicly accessible information does not contain nonpublic information.
- Review the proposed content of information prior to posting onto the publicly accessible information system to ensure that nonpublic information is not included.

Review the content on the publicly accessible information system for nonpublic information, immediately remove such information

REFERENCES:

- WyIT-3017 Remote Access

Review/Approval:

Date Issued/Review Date

This policy shall be reviewed at least annually and updated / reviewed / approved as defined in the Office of Chief Information Officer (OCIO) Policy lifecycle.

Factors that may trigger an out of cycle review are:

- Significant changes in administrative, legal, or regulatory requirements;
- Results of cybersecurity incidents or operational audits;
- Findings from compliance reviews or gap assessments;
- Changes in State or Federal policies impacting audit logging obligations; or
- Introduction of new technologies or retirement of existing systems that impact audit requirements.

The review and update process shall be coordinated by Governance, Risk and Compliance (GRC), completed by the policy owner and approved through the OCIO policy review workflow.

Approval

This policy must be signed by the appropriate officer (listed below) before it is considered approved and put into force.

The review and update process shall be coordinated by the GRC team, completed by the policy owner and approved through the OCIO policy review workflow.

Jeff Clines	Director
Officer Name	Officer Title
_____	_____
Officer's Signature	Date

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
July 2024	ETS Governance, Risk and Compliance	Public Comment Period	07/26/2024 - 08/09/2024	August 2024

REVISIONS			
REVISION DATE	**REVISED BY**	**SUMMARY OF REVISIONS**	**LAST APPROVED BY**
07/15/2026	ETS Governance, Risk and Compliance	Updated link(s) to the Security Exception Request Form to reflect a change in process.	June 2024

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**